

ZAP by Checkmarx

Scanning Report

Generated with  ZAP on Mon 1 Jun 2026, at 02:12:10

ZAP Version: 2.17.0

ZAP by Checkmarx

Contents

- [About This Report](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
 - [Insights](#)
- [Alerts](#)
 - [Risk=Medium, Confidence=High \(3\)](#)
 - [Risk=Medium, Confidence=Medium \(2\)](#)

- [Risk=Low, Confidence=Medium \(3\)](#)
- [Risk=Low, Confidence=Low \(1\)](#)
- [Risk=Informational, Confidence=Medium \(1\)](#)
- [Risk=Informational, Confidence=Low \(1\)](#)
- [Appendix](#)
 - [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <http://localhost:3000>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	High	Medium	Low	Total
Risk	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Medium	0 (0.0%)	3 (27.3%)	2 (18.2%)	0 (0.0%)	5 (45.5%)
	Low	0 (0.0%)	0 (0.0%)	3 (27.3%)	1 (9.1%)	4 (36.4%)
	Informational	0 (0.0%)	0 (0.0%)	1 (9.1%)	1 (9.1%)	2 (18.2%)
	Total	0 (0.0%)	3 (27.3%)	6 (54.5%)	2 (18.2%)	11 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High	Medium	Low	Informational
		(= High)	(>= Medium)	(>= Low)	(>= Informational)
http://localhost:3000	Site	0	5	4	2
		(0)	(5)	(9)	(11)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
CSP: Failure to Define Directive with No Fallback	Medium	5 (45.5%)
Content Security Policy (CSP) Header Not Set	Medium	5 (45.5%)
Total		11

Alert type	Risk	Count
Cross-Domain Misconfiguration	Medium	5 (45.5%)
Missing Anti-clickjacking Header	Medium	1 (9.1%)
Session ID in URL Rewrite	Medium	5 (45.5%)
Application Error Disclosure	Low	4 (36.4%)
Private IP Disclosure	Low	1 (9.1%)
Timestamp Disclosure - Unix	Low	5 (45.5%)
X-Content-Type-Options Header Missing	Low	3 (27.3%)
Information Disclosure - Suspicious Comments	Informational	3 (27.3%)
Modern Web Application	Informational	5 (45.5%)
Total		11

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	21
Low	Warning		ZAP warnings logged - see the zap.log file for details	43
Info	Informational	http://localhost:3000	Percentage of responses with status code 1xx	1 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 2xx	82 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 3xx	4 %
Info	Exceeded Low	http://localhost:3000	Percentage of responses with status code 4xx	11 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 5xx	1 %

Level	Reason	Site	Description	Statistic
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/javascript	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/json	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/octet-stream	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/jpeg	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/png	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image/x-icon	5 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/css	5 %

Level	Reason	Site	Description	Statistic
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/html	96 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/markdown	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text/plain	1 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method GET	99 %
Info	Informational	http://localhost:3000	Count of total endpoints	1,742
Info	Exceeded Low	http://localhost:3000	Percentage of slow responses	5 %

Alerts

Risk=Medium, Confidence=High (3)

<http://localhost:3000> (3)

CSP: Failure to Define Directive with No Fallback (1)

- ▶ GET <http://localhost:3000/assets>

Content Security Policy (CSP) Header Not Set (1)

- ▶ GET <http://localhost:3000>

Session ID in URL Rewrite (1)

- ▶ POST <http://localhost:3000/socket.io/?EI0=4&transport=polling&t=Pwln93L&sid=VlWPIJZrrCaf4CE7AAAE>

Risk=Medium, Confidence=Medium (2)

<http://localhost:3000> (2)

Cross-Domain Misconfiguration (1)

- ▶ GET <http://localhost:3000>

Missing Anti-clickjacking Header (1)

- ▶ POST <http://localhost:3000/socket.io/?EI0=4&transport=polling&t=Pwln93L&sid=VlWPIJZrrCaf4CE7AAAE>

Risk=Low, Confidence=Medium (3)

<http://localhost:3000> (3)

Application Error Disclosure (1)

- ▶ GET http://localhost:3000/api

Private IP Disclosure (1)

- ▶ GET http://localhost:3000/rest/admin/application-configuration

X-Content-Type-Options Header Missing (1)

- ▶ GET http://localhost:3000/socket.io/?EI0=4&transport=polling&t=Pwln8rE

Risk=Low, Confidence=Low (1)**http://localhost:3000 (1)****Timestamp Disclosure - Unix (1)**

- ▶ GET http://localhost:3000

Risk=Informational, Confidence=Medium (1)**http://localhost:3000 (1)****Modern Web Application (1)**

- ▶ GET http://localhost:3000

Risk=Informational, Confidence=Low (1)**http://localhost:3000 (1)**

Information Disclosure - Suspicious Comments (1)

- ▶ GET http://localhost:3000/chunk-7AKA75AX.js

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

CSP: Failure to Define Directive with No Fallback

Source	raised by a passive scanner (CSP)
CWE ID	693
WASC ID	15
Reference	▪ https://www.w3.org/TR/CSP/ ▪ https://caniuse.com/#search=content+security+policy ▪ https://content-security-policy.com/ ▪ https://github.com/HtmlUnit/htmlunit-csp ▪ https://web.dev/articles/csp#resource-options

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security)
---------------	--

Policy (CSP) Header Not Set)**CWE ID** [693](#)**WASC ID** 15**Reference**

- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP>
- https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
- <https://www.w3.org/TR/CSP/>
- <https://w3c.github.io/webappsec-csp/>
- <https://web.dev/articles/csp>
- <https://caniuse.com/#feat=contentsecuritypolicy>
- <https://content-security-policy.com/>

Cross-Domain Misconfiguration**Source** raised by a passive scanner ([Cross-Domain Misconfiguration](#))**CWE ID** [264](#)**WASC ID** 14**Reference**

- <https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy>

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Session ID in URL Rewrite

Source	raised by a passive scanner (Session ID in URL Rewrite)
CWE ID	598
WASC ID	13
Reference	▪ https://seclists.org/webappsec/2002/q4/111

Application Error Disclosure

Source	raised by a passive scanner (Application Error Disclosure)
CWE ID	550
WASC ID	13

Private IP Disclosure

Source	raised by a passive scanner (Private IP Disclosure)
---------------	---

CWE ID	497
WASC ID	13
Reference	▪ https://datatracker.ietf.org/doc/html/rfc1918

Timestamp Disclosure - Unix

Source	raised by a passive scanner (Timestamp Disclosure)
CWE ID	497
WASC ID	13
Reference	▪ https://cwe.mitre.org/data/definitions/200.html

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security-Headers

Information Disclosure - Suspicious Comments

Source	raised by a passive scanner (Information Disclosure - Suspicious Comments)
CWE ID	615
WASC ID	13

Modern Web Application

Source	raised by a passive scanner (Modern Web Application)
---------------	--